Lab 5: Static Code Analysis

Movie Review & Rating System (movie_reviews.py)

Name: Sahajpreet Singh

SRN: PES1UG24CS397

Assigned repo: L5_33_movie_reviews

Tools used: Pylint 4.1.3, Bandit 1.9.4, Flake8 7.5.0 (Python 3.13)

1. Introduction to Static Code Analysis

Static code analysis is the process of examining source code without executing it, in order to find bugs, security vulnerabilities, bad practices and style violations early, before the code is run or released. It is cheap to automate, gives fast feedback, and keeps a codebase consistent and maintainable. The goal of this lab was to run three static analysis tools on the assigned script (movie_reviews.py), document the issues they find, fix them, and verify the fixes by re-running the tools.

Tools used

- **Pylint:** a strict code reviewer. It checks code quality and logic, and reports unused or badly named variables, missing docstrings, poor practices and design problems, then gives the code a score out of 10.
- **Bandit:** a security scanner for Python. It looks for common vulnerabilities such as weak hashing (MD5), hardcoded passwords, insecure random number generators and binding to all network interfaces, and rates each finding by severity and confidence.
- **Flake8:** a style checker that enforces PEP 8. It combines pycodestyle, pyflakes and a complexity checker to report whitespace, blank-line, line-length and syntax problems.

Environment: Pylint 4.1.3, Bandit 1.9.4, Flake8 7.5.0 on Python 3.13, inside a virtual environment.

2. Original Program Output

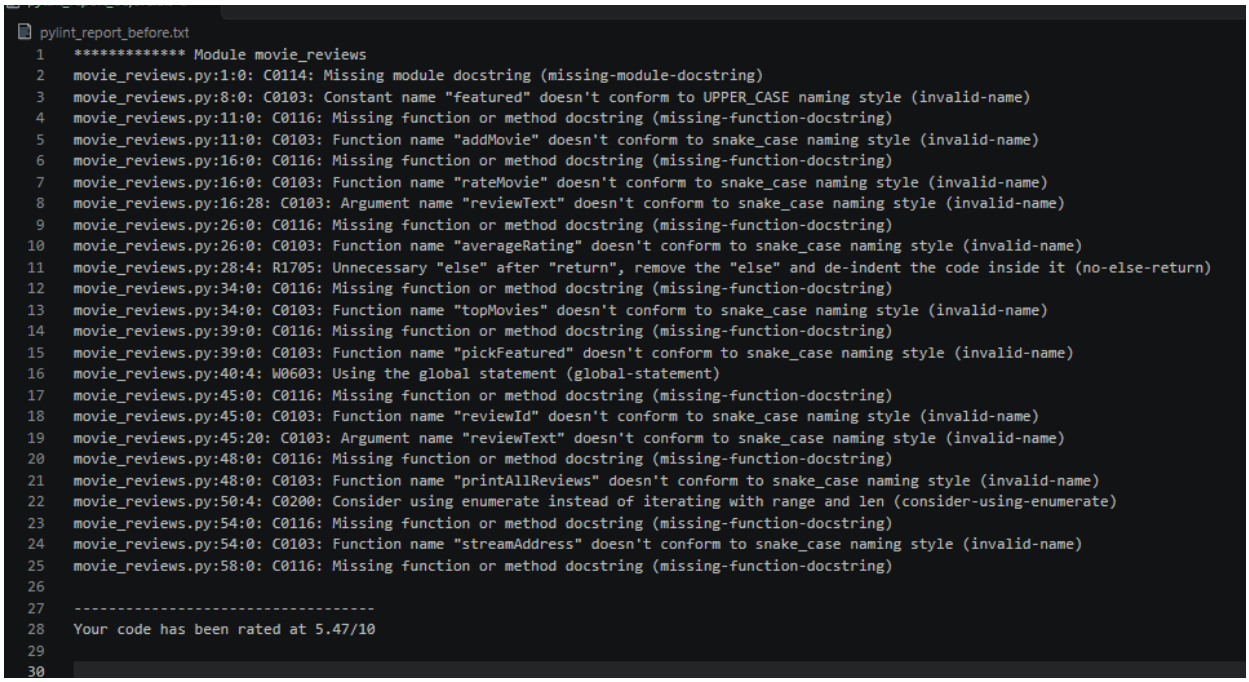
The program was run first to record its behaviour, so it could be compared after the fixes.

```
(venv) D:\se\lab5\L5_33_movie_reviews>python movie_reviews.py
Rating must be between 1 and 5, got 6
1 The Long Road 4.5
2 Laugh Track 2.0
3 Star Drift 4.0
Top movies: ['The Long Road', 'Star Drift']
Featured today: Laugh Track
Review id: 52e343ca87
Streaming from 0.0.0.0:8000
Genres: ['Comedy', 'Drama', 'Sci-Fi']
```

Figure 1: Output of the original movie_reviews.py

3. Static Analysis Reports (Before)

3.1 Pylint: 5.47/10



pylint_report_before.txt

```
************* Module movie_reviews
movie_reviews.py:1:0: C0114: Missing module docstring (missing-module-docstring)
movie_reviews.py:8:0: C0103: Constant name "featured" doesn't conform to UPPER_CASE naming style (invalid-name)
movie_reviews.py:11:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:11:0: C0103: Function name "addMovie" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:16:0: C0103: Function name "rateMovie" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:16:28: C0103: Argument name "reviewText" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:26:0: C0103: Function name "averageRating" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:28:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
movie_reviews.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:34:0: C0103: Function name "topMovies" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:39:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:39:0: C0103: Function name "pickFeatured" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:40:4: W0603: Using the global statement (global-statement)
movie_reviews.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:45:0: C0103: Function name "reviewId" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:45:20: C0103: Argument name "reviewText" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:48:0: C0103: Function name "printAllReviews" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:50:4: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
movie_reviews.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:54:0: C0103: Function name "streamAddress" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 5.47/10

```

Figure 2: pylint_report_before.txt

3.2 Bandit: 4 issues (1 High, 1 Medium, 2 Low)

bandit_report_before.txt

```
Run started:2026-10-30 02:49:31.556376+00:00

Test results:
>> Issue: [B104:hardcoded_bind_all_interfaces] Possible binding to all interfaces.
   Severity: Medium   Confidence: Medium
   CWE: CWE-605 (https://cwe.mitre.org/data/definitions/605.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b104_hardcoded_bind_all_interfaces.html
   Location: .\movie_reviews.py:4:14
3
4  STREAM_HOST = "0.0.0.0"
5  STREAM_PORT = 8000

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'reviews-demo'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\movie_reviews.py:6:21
5  STREAM_PORT = 8000
6  MODERATOR_PASSWORD = "reviews-demo"
7  movies = {}

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\movie_reviews.py:41:15
40     global featured
41     featured = random.choice(sorted(movies))
42     return featured

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\movie_reviews.py:46:11
45 def reviewId(title, reviewText):
46     return hashlib.md5((title + reviewText).encode()).hexdigest()[:10]
47


--------------------------------------------------

Code scanned:
   Total lines of code: 55
   Total lines skipped (#nosec): 0
   Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
   Total issues (by severity):
      Undefined: 0
      Low: 2
      Medium: 1
      High: 1
   Total issues (by confidence):
      Undefined: 0
      Low: 0
      Medium: 2
      High: 2
Files skipped (0):
```

Figure 3: bandit_report_before.txt

3.3 Flake8: 4 issues

flake8_report_before.txt

```
movie_reviews.py:35:11: E225 missing whitespace around operator
movie_reviews.py:48:1: E302 expected 2 blank lines, found 1
movie_reviews.py:70:67: E261 at least two spaces before inline comment
movie_reviews.py:72:20: E231 missing whitespace after ','
```

Figure 4: flake8_report_before.txt

4. Issues Identified and Fix Approach

Security findings are listed first, then code quality and style findings.

Issue	Type	Line(s)	Description	Fix Approach
Weak MD5 hash (B324)	Security, High	46	hashlib.md5 is a broken hash, flagged for security use	Switched to hashlib.sha256
Binding to all interfaces (B104)	Security, Medium	4	STREAM_HOST = "0.0.0.0" exposes the service on every network interface	Changed to 127.0.0.1 (localhost)
Hardcoded password (B105)	Security, Low	6	MODERATOR_PASSWORD stored as a plain string in source	Read from environment variable with os.environ.get
Insecure random (B311)	Security, Low	41	random.choice is not cryptographically secure	Replaced with secrets.choice
Global statement (W0603)	Design, Warning	40	global featured mutates module-level state, hard to track and test	Removed the global; pick_featured just returns the pick
Unnecessary else after return (R1705)	Refactor	28	else branch after return in averageRating	Removed else, de-indented
Range/len loop (C0200)	Refactor	50	for i in range(len(titles)) is non-idiomatic	Used enumerate(..., start=1)
Invalid names (C0103)	Convention	8, 11, 16, 26, 34, 39, 45, 48, 54	camelCase functions/arguments (addMovie, reviewText, ...) and lowercase module-level featured	Renamed to snake_case; module-level dict is now MOVIES; featured removed
Missing docstrings (C0114, C0116)	Convention	1, 11, 16, 26, 34, 39, 45, 48, 54, 58	No module or function docstrings	Added docstrings to the module and every function
Missing whitespace around operator (E225)	Style	35	ranked=sorted(...)	Added spaces around =
Expected 2 blank lines (E302)	Style	48	Only 1 blank line before function definition	Added second blank line
Inline comment spacing (E261)	Style	70	Only one space before # demo id	Two spaces before #
Missing whitespace after comma (E231)	Style	72	"Genres:",sorted(...)	Added space after comma
Unknown title crashes (bonus bug)	Bug	16-21	rateMovie raises KeyError if the movie does not exist	Added "if title not in MOVIES" guard

5. Key Code Changes

Security (Bandit)

```
# Before
STREAM_HOST = "0.0.0.0"
MODERATOR_PASSWORD = "reviews-demo"
featured = random.choice(sorted(movies))
return hashlib.md5((title + reviewText).encode()).hexdigest()[:10]

# After
STREAM_HOST = "127.0.0.1"
MODERATOR_PASSWORD = os.environ.get("MODERATOR_PASSWORD", "")
return secrets.choice(sorted(MOVIES))
digest = hashlib.sha256((title + review_text).encode()).hexdigest()
```

Code quality (Pylint)

```
# Before
def pickFeatured():
    global featured
    featured = random.choice(sorted(movies))
    return featured

# After
def pick_featured():
    """Pick a random movie to feature."""
    return secrets.choice(sorted(MOVIES))
```

Bug fix

```
if title not in MOVIES:
    print("Unknown movie:", title)
    return False
```

The fixes were made in three separate commits, one per tool (see Section 8).

6. Contents of All Six Reports (Before and After)

The text of each report file exactly as generated by the tools. "Before" reports were generated on the original code, "after" reports on the fixed code.

6.1 pylint_report_before.txt

```
************* Module movie_reviews
movie_reviews.py:1:0: C0114: Missing module docstring (missing-module-docstring)
movie_reviews.py:8:0: C0103: Constant name "featured" doesn't conform to UPPER_CASE naming style (invalid-name)
movie_reviews.py:11:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:11:0: C0103: Function name "addMovie" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:16:0: C0103: Function name "rateMovie" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:16:28: C0103: Argument name "reviewText" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:26:0: C0103: Function name "averageRating" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:28:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-
else-return)
movie_reviews.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:34:0: C0103: Function name "topMovies" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:39:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:39:0: C0103: Function name "pickFeatured" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:40:4: W0603: Using the global statement (global-statement)
movie_reviews.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:45:0: C0103: Function name "reviewId" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:45:20: C0103: Argument name "reviewText" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:48:0: C0103: Function name "printAllReviews" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:50:4: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
movie_reviews.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
movie_reviews.py:54:0: C0103: Function name "streamAddress" doesn't conform to snake_case naming style (invalid-name)
movie_reviews.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 5.47/10
```

6.2 pylint_report_after.txt

```

-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 5.47/10, +4.53)
```

6.3 bandit_report_before.txt

```
Run started:2026-10-30 02:49:31.556376+00:00

Test results:
>> Issue: [B104:hardcoded_bind_all_interfaces] Possible binding to all interfaces.
   Severity: Medium   Confidence: Medium
   CWE: CWE-605 (https://cwe.mitre.org/data/definitions/605.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b104_hardcoded_bind_all_interfaces.html
   Location: .\movie_reviews.py:4:14
3
4   STREAM_HOST = "0.0.0.0"
5   STREAM_PORT = 8000

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'reviews-demo'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\movie_reviews.py:6:21
5   STREAM_PORT = 8000
6   MODERATOR_PASSWORD = "reviews-demo"
7   movies = {}

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic
purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\movie_reviews.py:41:15
40      global featured
41      featured = random.choice(sorted(movies))
42      return featured

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
```

```
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\movie_reviews.py:46:11
45  def reviewId(title, reviewText):
46      return hashlib.md5((title + reviewText).encode()).hexdigest()[:10]
47

--------------------------------------------------

Code scanned:
    Total lines of code: 55
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 2
        Medium: 1
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 2
        High: 2
Files skipped (0):
```

6.4 bandit_report_after.txt

```
Run started:2026-10-30 02:58:50.018205+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 56
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

6.5 flake8_report_before.txt

```
movie_reviews.py:35:11: E225 missing whitespace around operator
movie_reviews.py:48:1: E302 expected 2 blank lines, found 1
movie_reviews.py:70:67: E261 at least two spaces before inline comment
movie_reviews.py:72:20: E231 missing whitespace after ','
```

6.6 flake8_report_after.txt

```
(empty file: Flake8 reported no issues)
```

7. Static Analysis Results (After Fixing)

Summary: before vs after

Tool	Before	After
Pylint	5.47 / 10	10.00 / 10
Bandit	4 issues (1 High, 1 Medium, 2 Low)	No issues identified
Flake8	4 issues	0 issues (empty report)

Pylint: 10.00/10

pylint_report_after.txt

pylint_report_after.txt

You, 11 minutes ago | author (You)

```
1
2   ------------------------------------------------------------------
3   Your code has been rated at 10.00/10 (previous run: 5.47/10, +4.53)
4
5
```

Figure 5: pylint_report_after.txt

Bandit: No issues identified

bandit_report_after.txt

You, 12 minutes ago | author (You)

```
1   Run started:2026-10-30 02:58:50.018205+00:00      You, 12 minutes ago • Lab5: fix Bandit issues (md
2
3   Test results:
4       No issues identified.
5
6   Code scanned:
7       Total lines of code: 56
8       Total lines skipped (#nosec): 0
9       Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
10
11  Run metrics:
12      Total issues (by severity):
13          Undefined: 0
14          Low: 0
15          Medium: 0
16          High: 0
17      Total issues (by confidence):
18          Undefined: 0
19          Low: 0
20          Medium: 0
21          High: 0
22  Files skipped (0):
23
```

Figure 6: bandit_report_after.txt

Flake8: no output (no issues)

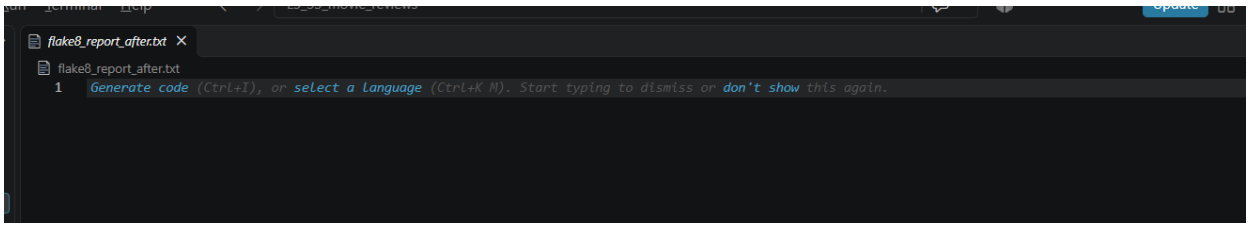


Figure 7: flake8_report_after.txt (empty report means no issues)

Program output after the fixes

Behaviour is unchanged. Only the host (127.0.0.1) and the review id (SHA-256 instead of MD5) differ, as expected. "Featured today" is random.

```
Rating must be between 1 and 5, got 6
1 The Long Road 4.5
2 Laugh Track 2.0
3 Star Drift 4.0
Top movies: ['The Long Road', 'Star Drift']
Featured today: Laugh Track
Review id: b8fc2faf6d
Streaming from 127.0.0.1:8000
Genres: ['Comedy', 'Drama', 'Sci-Fi']
```

8. Git Commits

One commit for each tool, as required.

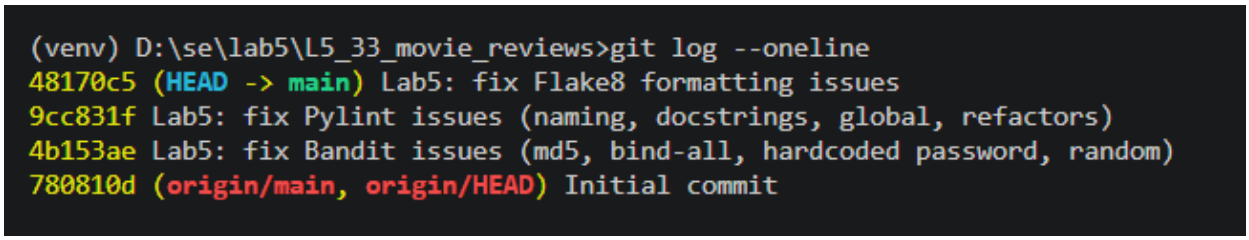


Figure 8: git log --oneline showing the three fix commits

9. Reflection

1. Which issues were the easiest and hardest to fix?

The easiest were the Flake8 ones (E225, E231, E261, E302). They were only whitespace and blank-line problems, and the report gave the exact line and column. The Bandit fixes were also simple: switching md5 to sha256, random to secrets, and 0.0.0.0 to 127.0.0.1 were one-line changes.

The hardest was the global featured warning from Pylint. Removing it meant changing how pick_featured works, so it now just returns the chosen movie instead of storing it in a module-level variable. The renaming to snake_case also took care, because every call site in main had to be updated or the program would break.

2. Did the tools report any false positives, or issues that do not matter much?

Mostly the findings were valid, but some had low real impact in this program. B311 (using random) is only a real problem if the value is security-sensitive, and picking a featured movie is not. B105 flagged MODERATOR_PASSWORD, but the value was only a demo string and it is never used for authentication. I still fixed both, because it is cheap and builds a good habit. The tools cannot know the context, so a developer still has to decide how serious each finding is.

3. How does static analysis improve code quality and security?

It catches problems without running the code. Bandit found a High severity issue (the weak MD5 hash) and a Medium one (binding to all network interfaces) that I would not have noticed just by running the program,

since it printed the correct output. Pylint pushed me to add docstrings, use consistent naming, and remove an unnecessary else and a range(len()) loop, which makes the code easier to read and maintain. Flake8 keeps the formatting consistent. Pylint also pointed out the awkward global state. My Pylint score went from 5.47/10 to 10.00/10.

4. How would you use static analysis in a real project?

I would run Flake8, Pylint and Bandit automatically, for example as a pre-commit hook or in a CI pipeline (like GitHub Actions) on every pull request, so that problems are caught before code is merged. I would fix the High and Medium Bandit findings first, set a minimum Pylint score, and document any warning that is intentionally ignored (using # nosec or # pylint: disable with a reason). Static analysis does not replace testing or code review, but it is a fast first check.